PENSE-BÊTE · MÉTHODES ET GOUVERNANCE

Gouvernance et Résilience Cyber 2026-2030

04-50 Gouvernance et Résilience La Stratégie Cybersécurité 2026-2030 — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. L'AI Act interdit les pratiques d'IA à risque inacceptable dès le 2 février 2025.
2. La directive NIS2 distingue les entités essentielles des entités importantes au sein de 18 secteurs d'activité.
3. Le label SecNumCloud garantit l'immunité aux lois extraterritoriales et l'usage de solutions qualifiées pour les données sensibles dès 2026.

Architecture normative européenne

Notion	À retenir
RGPD et IA	Complémentarité : l'**AI Act** facilite le **RGPD** via la **documentation technique**. L'**AI Act** interdit les pratiques à risque inacceptable dès **février 2025**.
Directive NIS2	Élargissement à **18 secteurs**. Entités **Essentielles** (surveillance **ex ante**) vs **Importantes** (surveillance **ex post**). Notification : avertissement sous **24 heures**, notification complète sous **72 heures**.
Cyber Resilience Act	Exigences pour produits matériels/logiciels. Sécurité sur tout le **cycle de vie**, **mises à jour automatiques par défaut** et signalement des vulnérabilités aux équipes nationales.

Référentiels techniques nationaux

Notion	À retenir
Sécurité et Interopérabilité	**RGS** : impose l'**homologation de sécurité** pour la cryptographie sous supervision de l'**ANSSI** ; **RGI** : privilégie **protocoles ouverts** et formats **non propriétaires**.
Accessibilité et Sobriété	**RGAA** : accès handicap obligatoire (sanction jusqu'à **25 000 euros** par an/service) ; **loi REEN** : **Référentiel Général d'Écoconception** avec **79 critères** pour réduire l'impact carbone.

Indicateurs et sanctions

79
Critères du Référentiel Général d'Écoconception de Services Numériques
issu de la **loi REEN**

10 M€ / 2 %
Sanction max. d'une entité essentielle NIS2 (CA mondial)

25 000 €
Sanction RGAA par an et par service

25 à 40 %
Surcoût du cloud SecNumCloud

déc. 2027
Obligations principales du CRA

Stratégie Nationale de Cybersécurité 2026-2030

Notion	À retenir
Objectifs de Souveraineté et de Formation	Réduction des dépendances via **cloud souverain** et **chiffrement post-quantique**. Création d'un **portail national unique** pour orienter la jeunesse et simplifier l'accès aux dispositifs.
Résilience Collective et Assistance	Généralisation des **exercices de crise cyber**. **Portail national unique** pour victimes, PME et collectivités. Capacité d'assistance cyber pour partenaires internationaux d'ici **2028**.

Gouvernance et acteurs institutionnels

Notion	À retenir
SGDSN et OSIIC	**SGDSN** : coordination interministérielle de crise, **secret de la défense**, **VIGINUM** (ingérences numériques). **OSIIC** : communications du Président et du Gouvernement (**230 000** mobiles, **90** ambassades).
Missions de l'ANSSI	**Défense/Réaction** : détecte les attaques. **Prévention/Conseil** : guides de bonnes pratiques. **Régulation** : visas de sécurité et supervision **NIS2**. **Veille** : bouclier numérique sur les vulnérabilités.

Résilience et Corruption

Notion	À retenir
Souveraineté Cloud / Continuité	Label **SecNumCloud** : immunité lois extraterritoriales et principe de composition. Dès **2026**, données sensibles sur solutions qualifiées. Clause de **réversibilité** indispensable.
Plan lutte corruption 2025-2029	Sécurisation des **fichiers de l'État**. Mesure de **criblage** (antécédents agents), plateforme de **signalement anonyme** et usage de l'**IA** par l'**AFA**.

Pièges et confusions

- ⚠ Confondre les entités essentielles (surveillance ex ante) et les entités importantes (surveillance ex post) sous NIS2.
- ⚠ Oublier que l'AI Act interdit les pratiques à risque inacceptable dès février 2025.
- ⚠ Confondre le RGS (confidentialité et intégrité) avec le RGI (standards ouverts et interopérabilité).
- ⚠ Ignorer que les obligations du Cyber Resilience Act ne s'appliqueront qu'à partir de décembre 2027.
- ⚠ Sous-estimer le surcoût du cloud SecNumCloud qui se situe entre 25 % et 40 % par rapport au cloud traditionnel.

Sigles et définitions

RGPD	Règlement Général sur la Protection des Données, pierre angulaire de la confiance numérique en Europe.
Directive NIS2	Norme européenne élargissant les obligations de cybersécurité à 18 secteurs d'activité.
CRA	Cyber Resilience Act imposant des exigences de cybersécurité pour tout produit comportant des éléments numériques.
ANSSI	Agence nationale de la sécurité des systèmes d'information, autorité technique de référence.
SecNumCloud	Label de l'ANSSI qualifiant les offres de cloud computing garantissant un haut niveau de sécurité.
OSIIC	Opérateur des Systèmes d'Information Interministériels Classifiés chargé des communications sécurisées des hautes autorités.

Auto-test

1. Quels sont les délais de notification sous NIS2 ?
2. Combien de critères compte le Référentiel Général d'Écoconception de Services Numériques ?
3. Quelle est la sanction financière maximale pour les entités essentielles sous NIS2 ?
4. Quel organisme coordonne l'action interministérielle en cas de crise majeure ?
5. Quelle est la sanction annuelle par service en cas de manquement au RGAA ?

Réponses : **1.** Avertissement sous 24 heures, notification complète sous 72 heures. · **2.** 79 critères. · **3.** Jusqu'à 10 millions d'euros ou 2 % du chiffre d'affaires mondial. · **4.** Le SGDSN. · **5.** Jusqu'à 25 000 euros.

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.